Industrial Security (Bachelor)

Solution Sheet – Section 04

Industrial Protocols

Exercise 4.1 – Modbus Frame

1. MBAP: Transaction ID = `0x0001`, Protocol ID = `0x0000` (always 0 for Modbus), Length = `0x0006` (6 bytes follow), Unit ID = `0x01`.
2. Function code = `0x03` = "Read Holding Registers".
3. Starting address = `0x0000`, quantity = `0x000A` = 10 registers.
4. Expected response (Unit ID 1, FC 03, byte count = $10 \times 2 = 20$):

```
00 01  00 00  00 17  01  03  14  00 00  00 00  00 00  00 00  00 00  00 00
00 00  00 00  00 00  00 00
```

   (Length = $1 + 1 + 1 + 20 = 23$ = `0x0017`.)

Exercise 4.2 – Lab Notes

The injection works because Modbus TCP has no authentication, no integrity, no encryption. Any host that can reach TCP/502 can write to any address. Mitigations:

- Network segmentation (only authorised hosts reach TCP/502).
- Industrial firewall with Modbus DPI (allowlist function codes per source).
- Modbus Security (TCP/802) with TLS – adoption is slow.
- Cryptographic wrappers / VPN tunnels.

Exercise 4.3 – OPC UA vs Modbus (key comparisons)

- **Authentication.** OPC UA: X.509 mutual + user. Modbus: none.
- **Integrity.** OPC UA: signed messages. Modbus: none beyond TCP checksum.
- **Confidentiality.** OPC UA: TLS / OPC UA `SignAndEncrypt`. Modbus: none.
- **Operational overhead.** OPC UA: certificate lifecycle management is non-trivial. Modbus: trivial to deploy, hence its persistence.

Exercise 4.4 – Protocol Selection (sample)

1. **IEC 61850** (MMS, GOOSE, SV) – it is the substation standard and provides standardised modelling.
2. **Modbus TCP via gateway**, isolated in the iDMZ, with passive replication to corporate. Pragmatic for retrofits.
3. **MQTT (Sparkplug B) with TLS**, brokered, certificate-authenticated. Suits sparse, many-publisher IIoT.